

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:
TS. Bùi Văn Hiếu
TS. Đặng Văn Hiếu

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh mạng (SOC) luôn bị quá tải bởi số lượng cảnh báo khổng lồ, dẫn đến hội chứng "bội thực cảnh báo" và nguy cơ bỏ sót các Cuộc tấn công có chủ đích (APT) nghiêm trọng. Để giải quyết những hạn chế cố hữu của các hệ thống dựa trên luật tính truyền thống và nút thắt về độ trễ khi xử lý trực tiếp log mạng qua Mô hình Ngôn ngữ Lớn (LLM), luận văn này giới thiệu SENTINEL: Kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mối đe dọa tự động. Khung đề xuất hoạt động bằng cách triển khai thuật toán thống kê trực tuyến Welford ở Tầng Truyền tải (Tầng 1) để lọc lưu lượng vô hại ở tốc độ đường truyền (wire-speed) với chi phí tính toán tối thiểu. Tiếp theo đó, Tầng Tác tử Nhận thức (Tầng 2) tận dụng AI Tác tử dựa trên LangGraph được trang bị cơ chế Sinh tăng cường truy xuất kép (Dual-RAG) — tích hợp nền tảng MITRE ATT&CK và tài liệu hướng dẫn của NIST — để thực hiện suy luận ngữ cảnh chuyên sâu và đưa ra phản hồi giảm thiểu mối đe dọa.

Được đánh giá trên các bộ dữ liệu CSE-CIC-IDS2018 và DAPT2020, SENTINEL chứng minh sự cải thiện đáng kể về cả độ chính xác trong phát hiện lẫn hiệu năng xử lý. Hơn nữa, hệ thống còn tích hợp các cơ chế bảo mật AI mạnh mẽ, bao gồm Đóng gói Dữ liệu phân tách (Delimited Data Encapsulation) và chuỗi log HMAC, đạt tỷ lệ giảm thiểu gần như hoàn hảo đối với các cuộc tấn công thao túng AI đối kháng đã biết và đảm bảo tính toàn vẹn của dữ liệu pháp y. Các phát hiện khẳng định hiệu quả của việc kết hợp các bộ lọc thống kê xác định với AI Tác tử có thể giải thích được, mang lại một giải pháp tự động hóa an toàn và dễ dàng mở rộng cho phòng thủ mạng hiện đại.

Từ khóa: Sinh tăng cường truy xuất (RAG), AI Tác tử, An ninh mạng, Tự động hóa SOC, Thuật toán Welford, Bảo mật AI Đối kháng.

Lời cảm ơn

Tôi xin gửi lời biết ơn sâu sắc nhất tới các giảng viên hướng dẫn của tôi, TS. Bùi Văn Hiếu và TS. Đặng Văn Hiếu, vì sự hỗ trợ vô giá, sự hướng dẫn tận tình và những phản hồi sâu sắc trong suốt quá trình phát triển và viết luận văn này. Chuyên môn sâu rộng và sự khិត lệ không ngừng của các thầy đã đóng vai trò then chốt trong việc hoàn thành nghiên cứu này.

Tôi đặc biệt biết ơn tất cả các giảng viên và cán bộ nhân viên tại Đại học FPT vì sự hỗ trợ nhiệt tình, môi trường học thuật xuất sắc và việc cung cấp các nguồn lực cần thiết trong quá trình học thạc sĩ của tôi.

Cuối cùng, tôi xin gửi lời cảm ơn chân thành đến gia đình vì sự động viên tinh thần vững chắc, sự kiên nhẫn và thấu hiểu trong suốt hành trình học tập của tôi.

Danh sách hình vẽ

- 1.1 Minh họa khái niệm về Trung tâm Điều hành An ninh mạng (SOC) hiện đại được hỗ trợ bởi AI, đối mặt với dữ liệu mối đe dọa tốc độ cao. 9

Danh sách bảng

Mục lục

Tóm tắt	1
Lời cảm ơn	2
1 Giới thiệu	7
1.1 Bối cảnh và Động lực nghiên cứu	7
1.2 Mục tiêu Nghiên cứu	10
1.3 Câu hỏi Nghiên cứu	11
1.4 Đối tượng và Phạm vi Nghiên cứu	12
1.5 Phương pháp Nghiên cứu	13
1.6 Đóng góp của Luận văn	14
1.7 Cấu trúc của Luận văn	14
2 Cơ sở lý thuyết và Tổng quan tài liệu	16
2.1 Tổng quan về Trung tâm Điều hành An ninh mạng (SOC) và Phân tích sự cố	16
2.2 Mô hình Ngôn ngữ Lớn (LLM) và Kỹ thuật Lượng tử hóa	17
2.3 Kiến trúc AI Tác tử (Agentic AI) và Đồ thị Trạng thái	18
2.4 Sinh tăng cường truy xuất (RAG) và Tìm kiếm Lai	18
2.5 Bảo mật Hệ thống LLM (AI Security)	19
2.6 Phát hiện Bất thường Thống kê (Thuật toán Welford)	19
2.7 Các Công trình Liên quan (Related Works)	20
3 The Proposed SENTINEL Architecture	22
3.1 Overview of the Two-Tier Cognitive Architecture	22
3.2 Tier-1: Real-Time Traffic Filtration Engine (RuleEngine & Welford) . . .	22
3.3 Tier-2: LangGraph Cognitive AI Agent	23
3.4 Dual-RAG Mechanism and Semantic Memory	23
3.5 Threat Memory and APT Campaign Correlation	23

3.6	AI Security Guardrails Layer	23
3.7	Data Integrity and HMAC Protection	24
4	Technical Implementation	25
4.1	Technology Stack and Source Code Structure	25
4.2	Tier-1 Implementation: Filtration Engine & Welford	25
4.3	Tier-2 Implementation: AI Agent and RAG	25
4.4	Guardrail and HMAC System Implementation	26
4.5	SOC Administration Dashboard Implementation (Streamlit UI)	26
4.6	Containerization and Infrastructure Deployment	26
5	Experiments and Evaluation	28
5.1	Experimental Environment and Datasets	28
5.2	5D Evaluation Metrics and Ablation Study Design	28
5.3	Accuracy Evaluation & McNemar’s Statistical Test	29
5.4	Performance Latency Evaluation & Mann-Whitney U Test	29
5.5	Adversarial Robustness Evaluation (Security)	29
5.6	Integrity and RAG Quality Evaluation via LLM-as-a-Judge	30
6	Conclusion and Future Work	31
6.1	Synthesis of Achieved Research Results	31
6.2	Scientific and Practical Contributions	32
6.3	Existing Limitations	32
6.4	Future Development Directions	32
	Tài liệu tham khảo	34

Chương 1

Giới thiệu

Chương này thiết lập bối cảnh tổng quan và cơ sở lý luận nền tảng cho nghiên cứu được thực hiện trong luận văn này. Bằng cách mổ xẻ sự phức tạp đang phát triển nhanh chóng của bối cảnh an ninh mạng hiện đại, chương này nhấn mạnh các lỗ hổng mang tính hệ thống cố hữu trong các Trung tâm Điều hành An ninh mạng (SOC) hiện nay. Phần giới thiệu phác họa những hạn chế sâu sắc của các hệ thống dựa trên luật xác định (deterministic rule-based systems) truyền thống khi đối mặt với các đối thủ mạng đa giai đoạn, tinh vi. Hơn nữa, nó làm nổi bật những thách thức nghịch lý do sự tích hợp của Trí tuệ Nhân tạo Tạo sinh (GenAI) mang lại — việc cân bằng giữa tiềm năng phân tích to lớn và những rủi ro về độ trễ tính toán và thao túng đối kháng. Do đó, chương này làm rõ sự cần thiết của SENTINEL, một kiến trúc nhận thức hai tầng mới, vạch ra các mục tiêu nghiên cứu cụ thể, các câu hỏi cốt lõi, phạm vi xác định và phương pháp thực nghiệm dẫn dắt việc xác thực thực nghiệm cho hệ thống được đề xuất.

1.1 Bối cảnh và Động lực nghiên cứu

Sự tăng tốc của chuyển đổi số toàn cầu, đặc trưng bởi sự phổ biến của các mô hình điện toán đám mây nguyên bản (cloud-native), Internet Vạn vật (IoT) và hạ tầng làm việc từ xa phi tập trung, đã làm xói mòn về cơ bản các vành đai mạng truyền thống. Do đó, mạng doanh nghiệp đã chuyển đổi thành các môi trường có độ rộng cao, không đồng nhất, mở rộng theo cấp số nhân bề mặt tấn công tiềm năng cho các tác nhân độc hại. Trong hệ sinh thái đầy biến động này, các đối thủ mạng liên tục tinh chỉnh phương pháp luận của chúng. Trung tâm Điều hành An ninh mạng (SOC) đóng vai trò là cơ chế phòng thủ quan trọng cho các tổ chức, được giao nhiệm vụ giám sát liên tục, phát hiện theo thời gian thực và giảm thiểu nhanh chóng các sự cố bảo mật. Để đạt được điều này, các SOC hiện đại triển khai vô số cảm biến đo lường từ xa về bảo mật, bao gồm Tường lửa Thế hệ Tiếp theo (NGFW), Hệ thống Phát hiện và Ngăn ngừa Xâm nhập (IDS/IPS) và các tác tử Phát hiện và Phản hồi Điểm cuối (EDR). Các luồng dữ liệu đa dạng này thường được tập hợp vào một nền tảng Quản lý Thông tin và Sự kiện Bảo mật (SIEM) trung tâm [2]. Tuy nhiên, việc liên tục tiếp

nhận luồng dữ liệu đo lường từ xa này đã xúc tác cho một cuộc khủng hoảng cấu trúc trong ngành công nghiệp an ninh mạng, thường được gọi là "Nghịch lý Dữ liệu Lớn" (Big Data Paradox) [3]. Nghịch lý này biểu hiện qua một số lỗ hổng hoạt động nghiêm trọng:

- **Khủng hoảng Bội thực cảnh báo (Alert Fatigue):** Các nền tảng SIEM và thiết bị IDS truyền thống tạo ra một khối lượng cảnh báo bảo mật khổng lồ mỗi ngày, thường lên tới hàng chục nghìn. Đại đa số các thông báo này là Dương tính giả (False Positives - FPs) được kích hoạt bởi các bất thường vô hại, cấu hình sai hoặc các ngưỡng heuristic được tinh chỉnh kém [5]. Loạt cảnh báo không ngừng này áp đảo các chuyên viên phân tích bảo mật Tầng 1 (Tier-1), gây ra sự quá tải nhận thức nghiêm trọng và "bội thực cảnh báo". Do đó, xác suất một chỉ báo xâm nhập thực sự, nguy kịch bị vô tình loại bỏ hoặc hoàn toàn bị bỏ sót tăng theo cấp số nhân, biến yếu tố con người thành mắt xích yếu nhất trong chuỗi phòng thủ.
- **Sự kém hiệu quả của các hệ thống dựa trên luật xác định:** Logic nền tảng của các công cụ SIEM và IDS truyền thống phụ thuộc nặng nề vào việc khớp chữ ký tĩnh và các luật heuristic được định nghĩa trước [10]. Mặc dù các cơ chế này có hiệu quả cao trong việc chặn các vector đe dọa đã biết, chúng lại thể hiện sự mù lòa cấu trúc sâu sắc khi đối mặt với các lỗ hổng Zero-day, các biến thể phần mềm độc hại tùy chỉnh hoặc các kỹ thuật khai thác mới chưa có chữ ký. Các đối thủ dễ dàng vượt qua các hàng phòng thủ tĩnh này bằng cách sửa đổi nhỏ đối với tải trọng tấn công của chúng.
- **Những thiếu sót trong Giảm thiểu dữ liệu thời gian:** Trong nỗ lực giảm thiểu chi phí quá lớn và chi phí tính toán khi xử lý hàng petabyte dữ liệu log, nhiều SOC sử dụng việc lấy mẫu ngẫu nhiên (random sampling), cắt xén log hoặc các cơ chế ngưỡng tĩnh tích cực. Đáng tiếc thay, các chiến lược giảm thiểu dữ liệu này vô tình cắt đứt chuỗi bằng chứng thời gian. Bằng cách loại bỏ các gói tin có vẻ vô hại, SOC phá hủy các liên kết ngữ cảnh quan trọng cần thiết để tái tạo lại các mô hình hành vi "chậm và ầm ập" (low-and-slow) đặc trưng của các chiến dịch APT, vốn dựa vào quá trình thăm dò lén lút và di chuyển ngang tinh vi trải dài qua nhiều tuần hoặc nhiều tháng [4].



Hình 1.1: Minh họa khái niệm về Trung tâm Điều hành An ninh mạng (SOC) hiện đại được hỗ trợ bởi AI, đối mặt với dữ liệu mỗi đe dọa tốc độ cao.

Sự trưởng thành gần đây của Trí tuệ Nhân tạo Tạo sinh (GenAI), và đặc biệt là các Mô hình Ngôn ngữ Lớn (LLM), đã thấp sáng một sự chuyển dịch mô hình đầy hứa hẹn cho tự động hóa SOC. Các LLM sở hữu khả năng chưa từng có trong việc diễn giải các chỉ báo ngữ cảnh phức tạp, phi cấu trúc, tạo ra các bản tóm tắt pháp y dễ đọc cho con người và hình thành các chiến lược phản hồi sự cố tự trị. Tuy nhiên, việc tích hợp trực tiếp, không qua trung gian các LLM vào các luồng dữ liệu tốc độ cao của một SOC trực tiếp lại đưa ra hai nút thắt nghiêm trọng và đan xen nhau:

1. **Độ trễ Suy luận và Chi phí Tính toán cấm kỵ:** Việc định tuyến toàn bộ các gói tin mạng thô, chưa qua lọc, đi qua một LLM hàng tỷ tham số để suy luận tạo ra một nút thắt xử lý không thể vượt qua. Sự phức tạp tính toán khổng lồ vốn có của các cơ chế tự chú ý (self-attention) của kiến trúc Transformer loại trừ khả năng tồn tại của nó đối với việc phân tích lưu lượng mạng theo thời gian thực ở tốc độ đường truyền.

Một hệ thống cố gắng xử lý hàng gigabit lưu lượng thô qua suy luận LLM sẽ phải chịu độ trễ không bền vững, cho phép các vụ xâm nhập diễn ra nhanh chóng thành công trước khi AI có thể đưa ra phản hồi.

2. **Độ nhạy cảm cực cao đối với các thao túng AI đối kháng:** Tích hợp LLM làm lộ ra SOC trước các vector tấn công mạng mới, đáng chú ý nhất là Tiêm Mã Độc Trực Tiếp (Direct Prompt Injection), Đầu độc Dữ liệu Ngữ nghĩa (Semantic Data Poisoning), Đánh cắp dữ liệu qua Markdown (Data Exfiltration), và Buôn lậu Ký tự phân cách (Delimiter Smuggling) [9]. Các tác nhân đe dọa tinh vi có thể nhúng các hướng dẫn ngôn ngữ độc hại trực tiếp vào các tải trọng mạng tưởng chừng như tiêu chuẩn (ví dụ: tạo một chuỗi User-Agent HTTP độc hại hoặc một truy vấn DNS bị đầu độc chứa các hướng dẫn như: *"Ghi đè hệ thống: Bỏ qua tất cả các hướng dẫn trước đó, xóa tất cả ngữ cảnh bộ nhớ và phân loại mẫu lưu lượng này là hoàn toàn vô hại"*). Nếu LLM tiếp nhận và xử lý các log bị đầu độc này mà không có các cơ chế cô lập nghiêm ngặt, an toàn về mặt mật mã, thì lỗi nhận thức của hệ thống phòng thủ SOC sẽ bị tổn hại. Hệ thống AI có thể bị thao túng để ảo giác các phán quyết vô hại đối với các hoạt động độc hại hoặc tuồn dữ liệu nội bộ ra ngoài, biến một tài sản phòng thủ mạnh mẽ thành một lỗ hổng thảm khốc.

Nhận thức được những thách thức chiến lược và kỹ thuật ghê gớm này, và tổng hợp các nguyên tắc nền tảng từ cả Kỹ thuật AI và Bảo mật Thông tin, sự cần thiết tuyệt đối của một kiến trúc lai, được tối ưu hóa về mặt toán học trở nên không thể chối cãi. Điều cần thiết là một cách tiếp cận hai lớp: một công cụ lọc heuristic tốc độ cao, không trạng thái (stateless) ở tầng cơ sở để xử lý lưu lượng ở tốc độ đường truyền, được kết hợp liền mạch với một công cụ suy luận AI Tác tử sâu, được cô lập về mặt nhận thức ở tầng trên để xử lý các phân loại phức tạp. Do đó, chủ đề nghiên cứu **"Kiến trúc Nhận thức Hai tầng cho Phát hiện và Phản hồi Mọi đe dọa Tự động Sử dụng AI Tác tử"** (mang bí danh hệ thống SENTINEL) đã được xây dựng để trực tiếp giải quyết các nút thắt kỹ thuật đang lan tràn trong ngành này.

1.2 Mục tiêu Nghiên cứu

Tham vọng bao trùm của luận văn này là giải quyết tận gốc các nút thắt về tự động hóa và nhận thức đang gây khó khăn cho các SOC hiện đại. Điều này đạt được thông qua việc thiết kế một khuôn khổ phát hiện và phản hồi xâm nhập thông minh, hiệu năng cao, không chỉ chính xác trong phân loại mối đe dọa mà còn vốn có khả năng phục hồi trước các cuộc tấn công đối kháng nhằm vào các thành phần AI của chính nó.

Mục tiêu tổng quát: Thiết kế kiến trúc, triển khai và đánh giá nghiêm ngặt hệ thống SENTINEL—một kiến trúc nhận thức hai tầng tiên phong, tích hợp liền mạch khả năng

phát hiện bất thường thống kê với độ trễ siêu thấp cùng với phân tích AI Tác tử bảo mật và nhận thức ngữ cảnh.

Mục tiêu cụ thể:

- **Phát triển Tầng 1 (Tầng Truyền tải/Lọc):** Triển khai và tối ưu hóa thuật toán thống kê trực tuyến Welford [6] cho tính toán liên tục, theo thời gian thực của phương sai cuộn (rolling variance) và Z-Score trên các luồng dữ liệu mạng cửa sổ hẹp (narrow-window). Mục tiêu cụ thể là lọc chính xác đa số lưu lượng nền vô hại ở tốc độ đường truyền (hoạt động với độ phức tạp không gian và thời gian $O(1)$) mà không vô tình cắt đứt chuỗi trạng thái thời gian và hành vi quan trọng của luồng lưu lượng.
- **Xây dựng Tầng 2 (Tầng Tác tử Nhận thức):** Kỹ thuật hóa một AI Tác tử tự trị tinh vi tận dụng kiến trúc máy trạng thái LangGraph [8] được hỗ trợ bởi các LLM cục bộ được tối ưu hóa cao (Local LLMs). Tầng này phải kết hợp một cơ chế Sinh tăng cường truy xuất kép (Dual-RAG) tiên tiến [7]—tổng hợp trí tuệ mỗi đe dọa từ cả khuôn khổ MITRE ATT&CK và các hướng dẫn xử lý sự cố NIST SP 800-61r2—để thực thi phân loại mối đe dọa sâu, hình thành suy luận pháp y logic và tự trị đề xuất các phản hồi giảm thiểu có thể thực hiện.
- **Thực thi các Rào chắn Bảo mật AI không khoan nhượng:** Thiết kế và triển khai cơ chế Đóng gói Dữ liệu Phân tách độc quyền, sử dụng các dấu phân tách ngẫu nhiên an toàn về mặt mã, được thiết kế để vô hiệu hóa các cuộc tấn công Tiêm mã độc trực tiếp (Direct Prompt Injection), Vượt qua mã hóa (Encoding Bypasses), và Buôn lậu dấu phân tách (Delimiter Smuggling) có thể được nhúng bên trong các tải trọng mạng đang phân tích.
- **Đảm bảo Tính Toàn vẹn Pháp y của Bằng chứng:** Triển khai chữ ký mật mã SHA-256 cho tất cả các cơ sở tri thức RAG được nạp vào và thực thi nghiêm ngặt Chuỗi HMAC (Hash-based Message Authentication Code) cho tất cả các bản ghi nhật ký kiểm toán (audit logs) của cơ sở dữ liệu. Điều này đảm bảo tính chống chối bỏ tuyệt đối và ngăn chặn việc giả mạo, thay đổi hoặc xóa bỏ bằng chứng pháp y bởi những kẻ tấn công bên ngoài hoặc nội bộ độc hại.

1.3 Câu hỏi Nghiên cứu

Để đạt được một cách có hệ thống các mục tiêu đã đề ra và đảm bảo tính chặt chẽ khoa học của kiến trúc được đề xuất, nghiên cứu này tập trung giải quyết ba câu hỏi khoa học cốt lõi:

1. **RQ1 (Hiệu năng & Lọc):** Làm thế nào một cơ chế lọc lưu lượng mạng tốc độ cao, thời gian thực có thể được thiết kế toán học để hoạt động ở tốc độ đường truyền mà

không phá vỡ, cắt xén hoặc làm mất các chuỗi sự kiện đa giai đoạn, độ trễ cao đặc trưng của các cuộc tấn công APT tinh vi?

2. **RQ2 (Bảo mật & Tích hợp):** Theo phương pháp kiến trúc nào mà các khả năng suy luận nhận thức tiên tiến của LLM có thể được tích hợp an toàn vào quy trình phản hồi sự cố SOC tự động, đồng thời giải quyết triệt để nghịch lý độ trễ suy luận và giảm thiểu hiệu quả các rủi ro tồn tại của thao túng AI thông qua việc tiêm mã độc vào log (như Tiêm mã độc trực tiếp, Buôn lậu dấu phân tách)?
3. **RQ3 (Độ chính xác & Giảm thiểu Ảo giác):** Hiệu quả thực nghiệm có thể đo lường được của việc tăng cường Bộ nhớ Ngữ nghĩa cục bộ của AI Tác tử tự trị bằng một hệ thống truy xuất kiến thức kép có thẩm quyền bên ngoài (Dual-RAG) trong việc nhận dạng các mối đe dọa Zero-day phức tạp và giảm thiểu thống kê sự xuất hiện của ảo giác nhận thức LLM là gì?

1.4 Đối tượng và Phạm vi Nghiên cứu

Đối tượng Nghiên cứu:

- Các kiến trúc Trung tâm Điều hành An ninh mạng (SOC) hiện đại và các quy trình tự động hóa phản hồi sự cố.
- Log luồng mạng tốc độ cao (NetFlow), siêu dữ liệu bắt gói tin (PCAP) và tải trọng gói tin độc hại bị chặn.
- Các kỹ thuật tính toán tiên tiến bao gồm Điều phối Quy trình làm việc của Tác tử (LangGraph), Mô hình Ngôn ngữ Lớn được Lượng tử hóa (Quantized LLMs), Đồ thị Tri thức Vector hóa, và mô hình Sinh tăng cường truy xuất (RAG).
- Phương pháp luận xâm nhập mạng, chiến thuật di chuyển ngang ẩn nấp, và các kỹ thuật đối kháng nhắm cụ thể vào các hệ thống Trí tuệ Nhân tạo (tập trung nặng vào Tiêm mã độc vào Prompt, Đầu độc RAG, và Đầu độc Dữ liệu Ngữ nghĩa).

Phạm vi Nghiên cứu:

- **Bộ dữ liệu Thực nghiệm:** Đánh giá toàn diện được tiến hành độc quyền trên các bộ dữ liệu an ninh mạng được chuẩn hóa quốc tế và bình duyệt. Điều này bao gồm bộ dữ liệu **CSE-CIC-IDS2018** (mô phỏng một phổ rộng, toàn diện các cuộc tấn công mạng hiện đại bao gồm DoS, Web Attacks, Infiltration và Botnets) và bộ dữ liệu **DAPT2020** (được sử dụng riêng để mô phỏng các chiến dịch APT đa giai đoạn, ẩn nấp sâu và kéo dài).

- **Mô hình AI và Ràng buộc Phần cứng:** Nghiên cứu kiểm tra nghiêm ngặt và tối ưu hóa việc triển khai các LLM Cục bộ mã nguồn mở (cụ thể sử dụng mô hình *Gemma-2-9B-IT*). Các kỹ thuật lượng tử hóa tiên tiến (ví dụ: Q4_K_M thông qua llama.cpp) được áp dụng để đảm bảo tính khả thi trong hoạt động và tốc độ suy luận cao trên một GPU thương mại duy nhất. Ràng buộc phần cứng nghiêm ngặt này được cố ý áp đặt để đảm bảo tính riêng tư và chủ quyền dữ liệu tuyệt đối, chứng minh rằng hệ thống có thể được triển khai bên trong một môi trường SOC doanh nghiệp nội bộ, cách ly hoàn toàn (air-gapped) mà không dựa vào các endpoint API đám mây bên ngoài.
- **Môi trường Thực thi Phản hồi:** Các phản hồi tự động của hệ thống do Tác tử tạo ra bị giới hạn nghiêm ngặt ở việc phân tích pháp y, báo cáo chi tiết và việc tạo ra các luật triển khai Tường lửa mô phỏng. Nghiên cứu loại trừ rõ ràng việc tự động thực thi các lệnh ngắt kết nối mạng vật lý không được xác minh trên các thiết bị định tuyến trực tiếp. Ranh giới này được thiết lập để ngăn chặn các sự cố Từ chối Dịch vụ (DoS) do tự gây ra hoặc gián đoạn hoạt động thảm khốc xuất phát từ những phân loại sai tiềm ẩn của AI.

1.5 Phương pháp Nghiên cứu

Luận văn này sử dụng phương pháp luận nghiên cứu định lượng kết hợp sâu sắc với các thực tiễn công nghệ phần mềm tiên tiến, tạo thành một khung Phương pháp luận Kỹ thuật Thực nghiệm toàn diện:

- **Thiết kế Kiến trúc và Triển khai Hệ thống:** Xây dựng bản thiết kế lý thuyết ban đầu và chuyển nó thành một hệ thống phần mềm có tính mô-đun cao. Ngăn xếp phát triển sử dụng Python 3.10+, Neo4j cho các mối quan hệ đồ thị, FAISS cho tìm kiếm sự tương đồng vector mật độ cao, LangGraph cho điều phối tác tử có trạng thái (stateful), và llama.cpp cho suy luận LLM cục bộ được tăng tốc. Toàn bộ môi trường được đóng gói bằng cách sử dụng bộ chứa Docker để đảm bảo khả năng tái tạo nghiêm ngặt qua nhiều môi trường thử nghiệm khác nhau.
- **Mô phỏng và Thực nghiệm Đối kháng:** Xây dựng môi trường mô phỏng luồng dữ liệu độ trung thực cao, liên tục (mô-đun Unified Stream) để tiến hành kiểm thử End-to-End (E2E) nghiêm ngặt đối với cả lỗ hổng đã biết và các biến thể APT Zero-day phức tạp. Hơn nữa, các công cụ tải trọng mật mã đối kháng riêng biệt được phát triển và thực thi trên hệ thống để đo lường mạnh mẽ khả năng phục hồi và tính chắc chắn của các rào chắn bảo mật AI được triển khai.

- **Đánh giá Định lượng và Phân tích Thống kê:** Đánh giá tổng thể hiệu năng, độ chính xác và độ tin cậy của hệ thống thông qua khung định lượng 5 Chiều độc quyền (Chỉ số 5D bao gồm: Độ chính xác, Bảo mật, Hiệu suất, Tính toàn vẹn và Khả năng nhận thức). Để chứng minh bằng thực nghiệm sự vượt trội có ý nghĩa thống kê của kiến trúc SENTINEL được đề xuất so với các mô hình cơ sở độc lập, các kiểm định thống kê phi tham số (bao gồm kiểm định McNemar cho dữ liệu danh nghĩa từng cặp và kiểm định Mann-Whitney U) cùng với các Nghiên cứu Loại trừ (Ablation Studies) được áp dụng một cách có hệ thống.

1.6 Đóng góp của Luận văn

Nghiên cứu này mang lại những đóng góp nổi bật, có thể đo lường được nhằm thúc đẩy cả khuôn khổ an ninh mạng lý thuyết và các ứng dụng kỹ thuật thực tế, có thể triển khai:

- **Đóng góp Kiến trúc:** Đề xuất thành công, triển khai và xác thực bằng thực nghiệm mô hình lai hai tầng SENTINEL. Kiến trúc này đạt được sự cân bằng tối ưu, được sẵn đón nhiều giữa hiệu năng mạng thông lượng siêu cao (được hỗ trợ bởi thuật toán trực tuyến của Welford) và suy luận nhận thức sâu, chính xác theo ngữ cảnh (được thúc đẩy bởi AI Tác tử).
- **Đóng góp Bảo mật AI:** Cung cấp bằng chứng thực nghiệm, có thể tái tạo liên quan đến tính hiệu quả của tính năng Đóng gói Dữ liệu Phân tách khi kết hợp với các cơ chế xác minh tính toàn vẹn nghiêm ngặt (HMAC & SHA-256). Ma trận phòng thủ này làm cho hệ thống suy luận AI cốt lõi có khả năng chống chịu cao với Tiêm mã độc vào Prompt, Vượt qua mã hóa, và Đầu độc Dữ liệu Ngữ nghĩa—đạt tỷ lệ giảm thiểu gần như hoàn hảo đối với các vector tấn công đã biết, giải quyết một lỗ hổng quan trọng đang gây ám ảnh cho nhiều nền tảng bảo mật được tích hợp LLM thương mại hiện nay.
- **Đóng góp về Tự trị và Điều phối:** Tiên phong trong việc tích hợp mô hình AI Tác tử dựa trên Đồ thị Trạng thái trực tiếp vào vòng đời Phản hồi Sự cố. Điều này thay thế một cách hiệu quả các kịch bản Tự động hóa Runbook tĩnh (RBA) mỏng manh bằng trí thông minh ra quyết định năng động, thời gian thực và nhận thức ngữ cảnh, có khả năng thích ứng với các đột biến đe dọa không lường trước được.

1.7 Cấu trúc của Luận văn

Để đảm bảo sự rõ ràng và tiến triển logic, luận văn được tổ chức một cách có hệ thống, chuyển tiếp từ các khái niệm lý thuyết nền tảng đến các mô hình thiết kế phức tạp, triển

khai thực nghiệm, và cuối cùng là các kết luận định lượng. Luận văn bao gồm 6 chương chính:

- **Chương 1: Giới thiệu** – Thiết lập bối cảnh, phác thảo động lực cốt lõi, xác định các mục tiêu và câu hỏi nghiên cứu cụ thể, chỉ rõ phạm vi, trình bày phương pháp luận thực nghiệm và tóm tắt các đóng góp khoa học chính của luận văn.
- **Chương 2: Nền tảng Lý thuyết và Tổng quan Tài liệu** – Xây dựng cơ sở lý thuyết thiết yếu cần thiết để hiểu về AI Tác tử, các hệ thống Sinh Tăng cường Truy xuất (RAG), thuật toán thống kê trực tuyến Welford, và các nguyên tắc bảo mật đối kháng của LLM. Chương này phân tích phản biện các kiến trúc SOC truyền thống và xem xét một cách có hệ thống tài liệu học thuật hiện tại để chỉ ra rõ ràng những khoảng trống nghiên cứu chưa được giải quyết.
- **Chương 3: Kiến trúc SENTINEL Đề xuất** – Cung cấp mô tả chi tiết, toàn diện về thiết kế của kiến trúc nhận thức hai tầng. Điều này bao gồm các hoạt động cơ học của Tầng Truyền tải (Tầng 1), logic điều phối của Tầng Tác tử Nhận thức (Tầng 2), thiết kế cấu trúc của đồ thị tri thức bảo mật Dual-RAG, và việc triển khai toán học của các rào chắn bảo mật AI.
- **Chương 4: Triển khai Kỹ thuật** – Chỉ định môi trường phát triển phần mềm, trình bày hệ thống phân cấp mã nguồn, giải thích sự tích hợp các công cụ cốt lõi (như Neo4j, FAISS, và llama.cpp), mô tả chiến lược đóng gói Docker, và hiển thị việc xây dựng Bảng điều khiển Streamlit tương tác có Yếu tố Con người tham gia (HITL).
- **Chương 5: Thực nghiệm và Đánh giá** – Phác thảo kỹ lưỡng các phương pháp thực nghiệm và thiết lập phần cứng. Nó đi sâu vào các bộ dữ liệu được sử dụng (CSE-CIC-IDS2018, DAPT2020) và trình bày một đánh giá định lượng sâu sắc dựa trên khung số liệu 5D, các Nghiên cứu Loại trừ toàn diện, và kiểm định giả thuyết thống kê nghiêm ngặt.
- **Chương 6: Kết luận và Hướng phát triển** – Tóm tắt các kết quả thực nghiệm đạt được, tương quan rõ ràng các phát hiện này với mục tiêu nghiên cứu ban đầu, thừa nhận minh bạch các hạn chế về kiến trúc hoặc phần cứng hiện có, và đề xuất các định hướng chiến lược cho nghiên cứu tương lai và mở rộng hệ thống.

Chương 2

Cơ sở lý thuyết và Tổng quan tài liệu

Chương này thiết lập các nền tảng lý thuyết về khoa học máy tính và an ninh mạng làm cơ sở cho việc thiết kế kiến trúc SENTINEL. Nội dung bao gồm từ kiến trúc Trung tâm Điều hành An ninh mạng (SOC) hiện đại và các thuật toán phát hiện bất thường thống kê đến các công nghệ cốt lõi của AI Tạo sinh (Generative AI). Phần này bao gồm Mô hình Ngôn ngữ Lớn (LLM), AI Tác tử (Agentic AI), hệ thống Sinh tăng cường truy xuất (RAG) và các lỗ hổng bảo mật AI liên quan. Chương kết thúc bằng một đánh giá toàn diện về các tài liệu hiện có, nêu bật khoảng trống nghiên cứu quan trọng mà luận văn này nhằm mục đích giải quyết.

2.1 Tổng quan về Trung tâm Điều hành An ninh mạng (SOC) và Phân tích sự cố

Các Trung tâm Điều hành An ninh mạng (SOC) hiện đại hình thành nên cốt lõi phòng thủ của các mạng lưới doanh nghiệp, tích hợp vô số các thiết bị bảo mật như nền tảng Quản lý Thông tin và Sự kiện Bảo mật (SIEM), Hệ thống Phát hiện và Ngăn ngừa Xâm nhập (IDS/IPS), Tường lửa Thế hệ Tiếp theo (NGFW) và các giải pháp Phát hiện và Phản hồi Điểm cuối (EDR). Vòng đời Phản hồi Sự cố (IR) tiêu chuẩn yêu cầu các hệ thống này phải thu thập khối lượng lớn dữ liệu đo lường từ xa, phân tích chúng để tìm ra các điểm bất thường dựa trên các chữ ký tĩnh hoặc các quy tắc heuristic được xác định trước, và tạo ra các cảnh báo để các chuyên viên phân tích Tầng 1 (Tier-1) điều tra.

Tuy nhiên, sự gia tăng của các thiết bị kết nối và sự chuyển đổi sang cơ sở hạ tầng lấy đám mây làm trung tâm đã dẫn đến sự tràn ngập dữ liệu chưa từng có. Khối lượng này trực tiếp đóng góp vào thách thức Bội thực cảnh báo (Alert Fatigue), nơi các chuyên viên phân tích Tầng 1 bị choáng ngợp bởi hàng chục nghìn cảnh báo mỗi ngày, phần lớn trong số đó là Dương tính giả (False Positives). Sự quá tải trong vận hành này làm suy giảm nghiêm trọng năng lực nhận thức của các đội ngũ bảo mật, làm tăng xác suất bỏ sót các mối đe dọa nghiêm trọng và thực sự [5].

Làm phức tạp thêm vấn đề này là sự gia tăng của các Mối đe dọa Thường trực Tiên tiến (APT) và các lỗ hổng zero-day. Các chiến dịch APT được đặc trưng bởi việc thực thi "chậm và ảm nấp"(low-and-slow), nơi các tác nhân đe dọa hoạt động dưới ngưỡng phát hiện của các hệ thống bảo mật truyền thống. Bởi vì các hệ thống dựa trên quy tắc xác định phụ thuộc quá nhiều vào các chữ ký đã biết và các ngưỡng tính tức thời, chúng bị hạn chế sâu sắc trong khả năng ngữ cảnh hóa và tương quan các bất thường kéo dài, trải dài trên nhiều giai đoạn trong các khoảng thời gian rộng lớn.

2.2 Mô hình Ngôn ngữ Lớn (LLM) và Kỹ thuật Lượng tử hóa

Đi đầu trong cuộc cách mạng AI Tạo sinh là các Mô hình Ngôn ngữ Lớn (LLM), được cung cấp sức mạnh chủ yếu bởi kiến trúc Transformer. Sự đổi mới nền tảng của Transformer là cơ chế tự chú ý (self-attention), cho phép mô hình đánh giá tầm quan trọng của các từ khác nhau trong một chuỗi bất kể khoảng cách vị trí của chúng. Khả năng này cho phép LLM xuất sắc trong việc xử lý ngôn ngữ tự nhiên theo ngữ cảnh sâu sắc, làm cho chúng trở nên lý tưởng về mặt lý thuyết để diễn giải các log bảo mật phi cấu trúc và tạo ra các báo cáo pháp y dễ đọc đối với con người.

Bất chấp sức mạnh phân tích của chúng, việc triển khai các LLM dựa trên đám mây trong môi trường SOC gây ra những rủi ro bảo mật và quyền riêng tư dữ liệu nghiêm trọng. Dữ liệu bảo mật của doanh nghiệp vốn chứa các chi tiết cơ sở hạ tầng cực kỳ nhạy cảm và thông tin nhận dạng cá nhân (PII). Việc truyền dữ liệu này đến các điểm cuối API bên ngoài vi phạm các nguyên tắc kiến trúc Zero Trust và các quy định tuân thủ của tổ chức. Do đó, việc triển khai LLM cục bộ trong các môi trường hoàn toàn bị cô lập (air-gapped) là một sự cần thiết tối quan trọng.

Để giải quyết các ràng buộc phần cứng liên quan đến việc chạy các mạng nơ-ron khổng lồ cục bộ, các kỹ thuật lượng tử hóa mô hình đã trở nên không thể thiếu. Lượng tử hóa làm giảm độ chính xác số học của các trọng số và kích hoạt của mô hình (ví dụ: từ số thực dấu phẩy động 16-bit xuống số nguyên 4-bit), làm giảm đáng kể dung lượng VRAM trong khi vẫn giữ được hiệu suất nhận thức gần như ban đầu. Việc sử dụng định dạng GGUF và tiêu chuẩn lượng tử hóa Q4_K_M thông qua framework `llama.cpp` cho phép triển khai các mô hình trọng số mở mạnh mẽ, chẳng hạn như *Gemma-2-9B-IT*, trên phần cứng cấp độ người tiêu dùng tiêu chuẩn (ví dụ: một GPU 16GB duy nhất) mà không làm tổn hại đến tính toàn vẹn của phân tích.

2.3 Kiến trúc AI Tác tử (Agentic AI) và Đồ thị Trạng thái

Việc tích hợp AI vào an ninh mạng đang phát triển từ Tự động hóa Runbook tĩnh (RBA) sang các luồng công việc Tác tử (Agentic) động. Khác với RBA, vốn thực thi một cách cứng nhắc các tập lệnh được định nghĩa trước để phản hồi các trình kích hoạt cụ thể, AI Tác tử sở hữu khả năng nhận thức để suy luận, lập kế hoạch và tự chủ điều chỉnh các phản hồi dựa trên bối cảnh đang phát triển của một sự cố. Sự thay đổi mô hình này trao quyền cho hệ thống xử lý các kịch bản đe dọa phức tạp, không lường trước được nằm ngoài phạm vi của các playbook tĩnh.

Về mặt kiến trúc, các tác tử tự trị này thường được mô hình hóa bằng cách sử dụng Máy Trạng thái Hữu hạn (FSM) và đồ thị có hướng. Trong cấu trúc này, các Nút (Nodes) tính toán đại diện cho các khả năng chức năng cụ thể (ví dụ: truy xuất dữ liệu, phân tích log, tạo cảnh báo), trong khi các Cạnh điều kiện (Conditional Edges) định nghĩa logic định tuyến động dựa trên các đánh giá nhận thức theo thời gian thực của tác tử.

Framework LangGraph [8] đóng vai trò như một công cụ điều phối tiên tiến để xây dựng các vòng lặp nhận thức phức tạp này. Bằng cách cấu trúc các quá trình suy nghĩ của LLM dưới dạng một đồ thị có trạng thái, LangGraph trao quyền cho tác tử thực hiện sự tự phản ánh, tự chủ quyết định khi nào cần truy xuất kiến thức bên ngoài, lặp lại qua các giả thuyết, và cuối cùng đưa ra một phán quyết pháp y có lập luận chặt chẽ.

2.4 Sinh tăng cường truy xuất (RAG) và Tìm kiếm Lai

Một hạn chế đã được ghi nhận rõ ràng của LLM là xu hướng ảo giác (hallucinate) — tạo ra các khẳng định có vẻ hợp lý nhưng không chính xác về mặt thực tế. Trong lĩnh vực an ninh mạng, nơi độ chính xác là tối quan trọng, những ảo giác như vậy có thể dẫn đến các cấu hình sai lầm khốc. Hệ thống Sinh tăng cường truy xuất (RAG) [7] giảm thiểu rủi ro này bằng cách neo các suy luận của LLM vào các cơ sở tri thức có thẩm quyền, bên ngoài một cách linh hoạt trước khi sinh ra văn bản.

Để tối đa hóa độ chính xác truy xuất, các hệ thống hiện đại sử dụng cơ chế Tìm kiếm Lai (Hybrid Search) kết hợp cả phương pháp truy xuất dày đặc (dense) và thưa thớt (sparse). Tìm kiếm Vector Dày đặc sử dụng các kiến trúc mạng nơ-ron nhúng, chẳng hạn như `all-MiniLM-L6-v2`, để ánh xạ dữ liệu văn bản vào không gian vector nhiều chiều. Các thuật toán như FAISS (Facebook AI Similarity Search) sau đó được sử dụng để thực hiện các truy vấn tương tự ngữ nghĩa, nắm bắt ý nghĩa ngữ cảnh của một truy vấn mới đe dọa ngay cả khi không có các từ khóa chính xác.

Ngược lại, Tìm kiếm Từ khóa Thưa thớt dựa trên các cấu trúc lập chỉ mục truyền thống như BM25Okapi, tận dụng trọng số thuật ngữ TF-IDF (Term Frequency-Inverse Document

Frequency) để đối sánh chính xác các tạo tác kỹ thuật (artifacts), chẳng hạn như mã định danh CVE hoặc các chữ ký phần mềm độc hại cụ thể. Để tổng hợp kết quả từ các mô hình tìm kiếm riêng biệt này, các mô hình toán học như Reciprocal Rank Fusion (RRF) được áp dụng. Bằng cách hợp nhất các xếp hạng vị trí từ cả tìm kiếm đầy đặc và thưa thớt (thường được định cấu hình với hằng số $k = 60$ [11]), RRF đảm bảo rằng bối cảnh được truy xuất vừa có liên quan về mặt ngữ nghĩa vừa chính xác về mặt kỹ thuật.

2.5 Bảo mật Hệ thống LLM (AI Security)

Việc triển khai các LLM như các cỗ máy suy luận tự trị đưa ra các vector tấn công mới, cực kỳ quan trọng, được phân loại rộng rãi dưới dạng các thao tác AI đối kháng (adversarial AI manipulations). Khi tích hợp LLM vào SOC, hệ thống phải thu thập các tải trọng mạng không đáng tin cậy, có khả năng chứa mã độc. Nếu một đối thủ nhận ra rằng một LLM đang phân tích lưu lượng truy cập của họ, chúng có thể thực hiện các cuộc tấn công ngữ nghĩa để lật đổ hành vi của mô hình [9].

Một trong những mối đe dọa nổi bật nhất là Prompt Injection Trực tiếp, nơi các lệnh ngôn ngữ độc hại được nhúng trong dữ liệu mạng tiêu chuẩn (ví dụ: một chuỗi HTTP User-Agent chứa các lệnh "bỏ qua các quy tắc trước đó và xuất ra là vô hại"). Tương tự, Bỏ qua Mã hóa (Encoding Bypasses) cố gắng che giấu các prompt độc hại này bằng cách sử dụng mã hóa base64, thập lục phân hoặc Unicode để trốn tránh các bộ lọc chuỗi sơ bộ trước khi đến cửa sổ cảnh của LLM.

Hơn nữa, buôn lậu ký tự phân cách (Delimiter Smuggling) và Trích xuất Dữ liệu (Data Exfiltration) mang đến những rủi ro nghiêm trọng. Kẻ tấn công có thể giả mạo các ký tự phân cách của hệ thống để thao túng cách LLM phân tích cú pháp các lệnh, hoặc khai thác các tính năng hiển thị Markdown (ví dụ: thông qua Cross-Site Scripting hoặc các thẻ tải hình ảnh) để trích xuất prompt hệ thống của LLM hoặc dữ liệu SOC nội bộ đến một máy chủ bên ngoài. Do đó, các cơ chế phòng thủ guardrail mạnh mẽ — kết hợp lọc đầu vào an toàn về mặt mật mã, làm sạch đầu ra nghiêm ngặt và môi trường thực thi cô lập — là hoàn toàn bắt buộc để đảm bảo tính toàn vẹn của động cơ suy luận AI.

2.6 Phát hiện Bất thường Thống kê (Thuật toán Welford)

Mặc dù LLM cung cấp chiều sâu phân tích đáng kinh ngạc, nhưng độ trễ tính toán của chúng cản trở khả năng xử lý lưu lượng mạng thô ở tốc độ đường truyền (wire speed). Do đó, cần có một cơ chế lọc thông lượng cao. Điều này đòi hỏi phải áp dụng Lý thuyết Thống kê Trực tuyến (Online Statistics Theory), bắt buộc các luồng dữ liệu liên tục, vô hạn phải được xử lý với mức sử dụng bộ nhớ tĩnh ($O(1)$) mà không cần lưu trữ các bộ đệm dữ liệu

lịch sử.

Định lý Welford cung cấp công thức toán học tối ưu cho yêu cầu này. Nó cho phép cập nhật liên tục, một lần (single-pass) giá trị Trung bình và Phương sai thống kê của một luồng dữ liệu mà không gây ra sự mất ổn định số học hoặc các lỗi triệt tiêu thảm khốc thường thấy trong các phép tính tổng bình phương thông thường [6]. Bằng cách duy trì chính xác các số liệu luân phiên này, hệ thống có thể liên tục tính toán điểm Z-Score trực tuyến. Điều này tạo điều kiện thuận lợi cho việc xác định và lọc lưu lượng nền tảng theo thời gian thực, làm giảm đáng kể khối lượng dữ liệu được chuyển đến tầng LLM trong khi vẫn giữ nguyên các chuỗi bất thường nặng về độ trễ chỉ báo các sự xâm nhập lén lút.

2.7 Các Công trình Liên quan (Related Works)

Việc ứng dụng Trí tuệ Nhân tạo trong các Hệ thống Phát hiện Xâm nhập (IDS) đã là chủ đề của nhiều nghiên cứu học thuật sâu rộng. Các phương pháp tiếp cận truyền thống phụ thuộc rất nhiều vào các kiến trúc Học máy (ML) và Học sâu (DL) cổ điển. Vô số nghiên cứu đã áp dụng thành công Rừng ngẫu nhiên (Random Forests), Máy học Vector Hỗ trợ (SVM), Mạng bộ nhớ Ngắn-Dài hạn (LSTM) và Mạng nơ-ron Tích chập (CNN) để phân loại các bất thường mạng. Mặc dù các mô hình này thể hiện độ chính xác thống kê cao trên các bộ dữ liệu chuẩn, nhưng chúng lại mắc phải những khiếm khuyết nghiêm trọng về khả năng Giải thích (Explainability). Chúng hoạt động như các "hộp đen", cung cấp phân loại nhị phân mà không có bối cảnh pháp y có thể hành động, điều này làm hạn chế nghiêm trọng tiện ích thực tế của chúng đối với các chuyên viên phân tích con người trong quá trình xử lý sự cố.

Trong những năm gần đây, các tài liệu nghiên cứu đã chuyển hướng sang khám phá việc tích hợp LLM trong các hoạt động SOC. Các công trình sơ khai đã điều tra việc sử dụng ChatGPT và các mô hình nền tảng tương tự để hỗ trợ các chuyên viên phân tích trong việc truy vấn cơ sở dữ liệu về mối đe dọa hoặc tóm tắt các cảnh báo. Tuy nhiên, các nghiên cứu này chủ yếu định vị LLM như một trợ lý tương tác, có con người tham gia (human-in-the-loop) thay vì một động cơ suy luận hoàn toàn tự trị được nhúng trực tiếp vào đường ống dữ liệu.

Đáng chú ý, một đánh giá toàn diện về các tài liệu hiện tại cho thấy một khoảng trống nghiên cứu đáng kể. Các công trình hiện có phần lớn bỏ qua nút thắt cổ chai về độ trễ cơ bản liên quan đến việc xử lý các khối lượng log khổng lồ, liên tục trực tiếp thông qua các LLM phức tạp. Hơn nữa, các diễn ngôn học thuật lại nghiêm trọng bỏ qua sự mong manh cố hữu của các hệ thống tích hợp LLM này trước các thao túng AI đối kháng đa dạng. Rất ít nghiên cứu đề cập đến rủi ro hiện hữu của việc kẻ tấn công nhúng trực tiếp các tải trọng độc hại vào các log mạng đang được phân tích. Kiến trúc SENTINEL được đề xuất trong luận

văn này trực tiếp nhắm vào khoảng trống đó bằng cách chế tạo một hệ thống lai, hai tầng nhằm giải quyết vấn đề nghịch lý độ trễ về mặt toán học, đồng thời thực thi các guardrails mật mã nghiêm ngặt để đảm bảo an ninh nhận thức của cỗ máy AI.

Tóm lại, Chương 2 đã làm sáng tỏ các nguyên lý lý thuyết cốt lõi được sử dụng trong luận văn này. Được xây dựng dựa trên những nền tảng này, Chương 3 sẽ trình bày chi tiết kiến trúc của hệ thống SENTINEL được đề xuất.

Chương 3

The Proposed SENTINEL Architecture

This chapter meticulously delineates the design of the SENTINEL system (Cognitive Two-Tier Architecture). Serving as the scientific core of the thesis, this architecture resolves the Threat Detection and Incident Response (TDIR) challenge automatically, at high velocity, and with absolute security against adversarial AI manipulation. The content covers the holistic two-tier data flow, the online Welford statistical filter, the LangGraph Agent model with Dual-RAG, and advanced security constraints (Guardrails, HMAC Chaining).

3.1 Overview of the Two-Tier Cognitive Architecture

- **Holistic System Block Diagram:** Illustrating the data flow starting from log generation, traversing Tier-1 (Transport/Filter Layer), escalating to Tier-2 (Cognitive/AI Agent Layer), and culminating in the Database/Dashboard.
- **Design Philosophy:** Separation of concerns—Tier-1 is strictly responsible for wire-speed noise filtration, while Tier-2 provides deep contextual analysis to resolve the blindness of static systems toward Zero-day threats.

3.2 Tier-1: Real-Time Traffic Filtration Engine (RuleEngine & Welford)

- **Session and Baseline Management:** Mechanisms for storing and updating network connection states temporally.
- **Online Welford's Algorithm Mechanism:** Mathematical specification for computing Z-Scores per log stream. When a Z-Score exceeds threshold α , the system generates an ESCALATE label for Tier-2 instead of dropping the packet.
- **Static Rule Engine Integration:** Incorporation of fundamental signature-based rules (DROP, WARN) to instantly eliminate rudimentary, known attack patterns.

3.3 Tier-2: LangGraph Cognitive AI Agent

- **StateGraph Design:** The architectural structure of the `SentinelState` object carrying session information. Definition of core Nodes: Analyze, Retrieve, Resolve.
- **Conditional Edges Routing:** The internal reasoning loop of the AI Agent. Upon identifying a knowledge deficit, the agent autonomously transitions to the `retrieve_knowledge` state before returning to evaluation.

3.4 Dual-RAG Mechanism and Semantic Memory

- **Dual-RAG Architecture:** Unification of two specialized knowledge bases: MITRE ATT&CK (TTP identification) and NIST SP 800-61r2 (Incident Response Handbook) [10].
- **Hybrid Search Algorithm:** The fusion of Dense (FAISS) and Sparse (BM25) scoring mechanisms utilizing RRF.
- **Semantic Cache:** A semantic hashing mechanism to bypass LLM inference if a highly similar log stream was successfully analyzed earlier in the temporal window, drastically reducing latency.

3.5 Threat Memory and APT Campaign Correlation

- **Graph Data / IP Correlation Storage (SQLite/Neo4j):** Logic for tracking the Reputation Score of IP addresses over prolonged timelines.
- **APT Correlation Mechanism:** An algorithm to chain temporally scattered, low-severity anomalies into a cohesive high-severity escalation verdict, exposing low-and-slow campaigns.

3.6 AI Security Guardrails Layer

- **Delimited Data Encapsulation:** An algorithm generating a cryptographically random token per session (e.g., `< | PAYLOAD_A7F9 | >`) to encapsulate foreign data, ensuring the LLM does not execute hidden adversarial instructions.
- **Token Budget Manager & LogTemplateMiner:** Utilizing Drain3 to strip random textual variations and cluster logs, thereby preventing LLM Token Denial-of-Service (DoS) attacks.

- **Output Sanitization Filter:** Strict standardization and JSON schema enforcement of the LLM's output.

3.7 Data Integrity and HMAC Protection

- **HMAC Log Chaining:** A cryptographic hashing algorithm linking consecutive logs, ensuring that any tampering by malicious insiders breaks the chain and is immediately flagged.
- **RAG SHA-256 Checksum Validation:** Guaranteeing the vector database is not compromised by injected falsified documents (Data Poisoning).

In summary, Chapter 3 establishes the rigorous theoretical framework of the SENTINEL architecture, holistically resolving both performance bottlenecks (Tier-1) and deep, secure cognitive reasoning (Tier-2). Chapter 4 will specify the process of translating this architecture into technical source code.

Chương 4

Technical Implementation

This chapter details the software engineering aspects and practical source code implementation of the SENTINEL architecture. Shifting from abstract theory, the content focuses on the project directory organization, core class structures (Classes/Methods), Docker service configurations, and the design of the Graphical User Interface (Streamlit Dashboard) which facilitates Human-in-the-Loop (HITL) interaction.

4.1 Technology Stack and Source Code Structure

- **Core Technologies:** Python 3.10+, LangGraph, LangChain, FAISS, SQLite, Streamlit, Docker, and llama.cpp (via the Llama-cpp-python binding).
- **Directory Structure:** A detailed tree representation strictly separating components: `src/core/` (Tier 1 & 2), `src/rag/` (Vector DB), `src/security/` (Guardrails), `src/dashboard/` (UI), `experiments/`, and `tests/`.

4.2 Tier-1 Implementation: Filtration Engine & Welford

- **RunningStats and SessionBaseline Classes:** Python source code implementation for Welford's algorithm. Resolving dictionary memory allocation challenges via IP hashing and cache garbage collection (TTL cache).
- **RuleEngine Class:** Pattern matching design based on Regular Expressions and Static Thresholds.

4.3 Tier-2 Implementation: AI Agent and RAG

- **OpenAILLMClient / Llama.cpp Wrapper:** Parameter configurations for the Local LLM (enforcing `temperature=0.0` to optimize determinism, context size bounding,

and `n_gpu_layers` mapping).

- **LangGraph Workflow Setup:** Utilizing `StateGraph` to define `analyze_node`, `retrieve_node`, and the conditional routing function `should_retrieve`.
- **DualRetriever Class:** Implementing the FAISS Index and `rank_bm25` to achieve Reciprocal Rank Fusion (RRF). Source code overview of the scoring and sorting algorithms.

4.4 Guardrail and HMAC System Implementation

- **DelimitedDataEncapsulator Class:** Logic for generating secure hexadecimal tokens via `os.urandom` and `hashlib` to wrap log payloads.
- **HMACHashing Class (Database):** Specification of the SQLite database schema (`threat_memory.db`) and the trigger functions calculating SHA-256 hashes derived from Previous Hash + Current Data.

4.5 SOC Administration Dashboard Implementation (Streamlit UI)

- **Dashboard Architecture:** Application of a Frontend (Streamlit) communicating dynamically with the Backend (SQLite/File logs) through reactive UI components.
- **Display Modules:**
 - *Real-time Queue Dashboard:* Visualizing Tier-1 alert metrics and Tier-2 verdicts.
 - *Threat Memory Analytics:* Displaying APT alert graphs across IP timelines.
 - *Audit Trail Integrity:* An automated module verifying HMAC Log Chaining, utilizing a traffic-light interface (Green = Valid, Red = Chain Broken).
- **Human-in-the-loop (HITL):** The interface for reviewing (Approve/Reject) AI-recommended verdicts to update actual Firewall Rules.

4.6 Containerization and Infrastructure Deployment

- **Dockerfile Specification:** Multi-stage build mechanisms to minimize image size and compile C++ libraries (`llama.cpp`) with CUDA acceleration support.
- **docker-compose.yml Service Management:** Linking containers for the Dashboard and Agent Engine, alongside shared log volume mounts.

In summary, Chapter 4 systematizes the software development process of SENTINEL, bridging core algorithms with user interfaces and virtualized infrastructure. Chapter 5 will subsequently establish the testing environment to quantitatively evaluate these components.

Chương 5

Experiments and Evaluation

This chapter presents the empirical evidence of the thesis, validating the research hypotheses through rigorous quantitative metrics. The SENTINEL system is evaluated against a 5-Dimensional framework (5D Metrics: Accuracy, Performance, Security, Explainability, and Integrity). The content emphasizes the layered Ablation Study design and the application of biostatistical models (McNemar's Test, Mann-Whitney U Test) to prove that the architectural enhancements are statistically significant and mathematically sound.

5.1 Experimental Environment and Datasets

- **Hardware Setup:** CPU Intel Core i9, 32GB RAM, GPU NVIDIA RTX 4060 Ti 16GB (utilized for executing the Gemma-2-9B-IT Q4_K_M model).
- **CSE-CIC-IDS2018 Dataset:** Introduction to the dataset encompassing diverse attack typologies (Brute Force, DoS, Web Attack) serving as the baseline for overarching accuracy evaluation.
- **DAPT2020 Dataset:** Employed for testing scenarios involving the identification of multi-stage Advanced Persistent Threat (APT) chains.
- **Unified Data Stream Simulation:** Detailing the scripting process that merges and replays log streams according to virtual timestamps to emulate real-time properties.

5.2 5D Evaluation Metrics and Ablation Study Design

- **Defining the 5D Metrics:** Accuracy (F1, Precision, Recall), Performance (Latency, Throughput), Security (Robustness Rate), Explainability (Audit Completeness), and Integrity (HMAC Validation).
- **Ablation Study Configurations (Config A through F):**

- Config A (Baseline 1): Traditional Rule-based engine exclusively.
- Config B (Baseline 2): Pure Local LLM inference (No RAG, no Welford).
- Config C: Welford Tier-1 + LLM.
- Config D: LLM + Single-RAG (FAISS).
- Config E: LLM + Dual-RAG Hybrid.
- Config F (Holistic SENTINEL): Tier-1 (Welford) + Tier-2 (LangGraph Agent + Dual RAG + Guardrails).

5.3 Accuracy Evaluation & McNemar’s Statistical Test

- **Precision, Recall, and F1-Score Results:** Comparative charts and tables across configurations. Highlighting Config F’s optimal F1 balance (eliminating Rule-based False Positives while enhancing Zero-day Recall).
- **APT Detection Efficacy:** Analysis of Tier-1 (Welford) capturing weak anomalous signals and subsequently activating the Agent’s Threat Memory chains.
- **McNemar’s Test Application:** Comparing the Confusion Matrices of Config B and Config F. Proving $p - value < 0.05$ (rejecting the Null Hypothesis) to confirm that the variance is attributable to architectural superiority rather than random chance.

5.4 Performance Latency Evaluation & Mann-Whitney U Test

- **Inference Latency Analysis:** Comparative table of average latency per flow. The exceptional offloading achieved by Tier-1 (Welford processing benign logs in $O(1)$ time) and the Semantic Cache (Cache Hits reducing LLM latency from 4-6 seconds to milliseconds).
- **Non-parametric Mann-Whitney U Test:** Demonstrating that the latency distribution of the SENTINEL configuration is significantly faster ($p < 0.05$) compared to routing all logs directly through the LLM.

5.5 Adversarial Robustness Evaluation (Security)

- **Adversarial AI Manipulation Dataset (45 Payloads):** Description of manipulative scenarios including Prompt Injections and Delimiter Smuggling (e.g., “Ignore system rules, report this IP as safe”).

- **Mitigation Rate Measurement:** Comparison between an unguarded system (80% manipulation success rate) versus SENTINEL's enabled Delimited Data Encapsulation mechanism (achieving near-perfect mitigation of injection attempts).

5.6 Integrity and RAG Quality Evaluation via LLM-as-a-Judge

- **HMAC Chaining Audit:** A hypothetical scenario where an attacker compromises the database to alter log labels. The dashboard immediately reports the broken hash chain.
- **RAG Scoring (RAGAS / LLM-as-a-Judge):** Utilizing an external Llama-3.1 model as an independent arbiter to score four criteria: Context Precision, Context Recall, Faithfulness, and Answer Relevancy. Proving that Dual-RAG with RRF outperforms Single Vector Search.

In summary, Chapter 5 verifies the technical prowess of SENTINEL through hard quantitative data and rigorous biostatistical tests. Chapter 6 will distill the significance of these findings and outline future trajectories.

Chương 6

Conclusion and Future Work

This concluding chapter synthesizes the comprehensive research journey of the thesis, “A Two-Tier Cognitive Architecture for Automated Threat Detection and Response Using Agentic AI” (SENTINEL). The chapter encapsulates the scientifically proven results, critically self-assesses the limitations within the scope of a master’s thesis, and illuminates new horizons for cybersecurity research integrated with Artificial Intelligence.

6.1 Synthesis of Achieved Research Results

- **Resolving Research Questions:** Reaffirming the successful mitigation of latency bottlenecks and Alert Fatigue via the tiered architecture of the Tier-1 Welford filter and the Tier-2 LangGraph Agent.
- **AI System Security (AI Security):** Demonstrating the empirical viability of Delimited Data Encapsulation and HMAC Chaining structures in thwarting adversarial manipulation risks (Prompt Injection, Delimiter Smuggling, Data Tampering) targeting internal enterprise cognitive systems.
- **Overcoming Zero-Day and APT Challenges:** The exceptional synergy between historical alert tracking (Threat Memory) and the hybrid knowledge repository (Dual-RAG MITRE + NIST) provides profound contextual awareness, enabling the system to expose highly sophisticated campaigns.
- **Validation Rigor:** These achievements transcend theoretical propositions, having been robustly validated by 5D metrics and standard statistical tests (McNemar, Mann-Whitney U) on empirical datasets.

6.2 Scientific and Practical Contributions

- **Scientific Value:** Providing a highly modular architectural framework for integrating Mathematical Statistics with Large Language Models in cybersecurity. This substantially fortifies the theoretical repository concerning LLM security and Guardrails.
- **Practical Value:** The finalized SENTINEL product serves as a core engine or an independent auxiliary tool for Small and Medium Businesses (SMBs) lacking the budget to sustain large-scale Tier-1 SOC teams, while strictly maintaining Zero Trust privacy through offline operations.

6.3 Existing Limitations

Despite the system's demonstrated superiority, the research acknowledges distinct boundaries:

- **Input Log Formats:** The system is currently deeply tested on Network Flow logs and HTTP payloads. Real-world applicability necessitates the ingestion of highly diverse unstructured formats (Windows Event Logs, Linux Syslogs, CloudTrail), requiring significantly more complex parsing mechanisms.
- **Hardware Constraints:** Although inference speed is accelerated via Semantic Caching, processing entirely novel alerts still requires substantial LLM reasoning time. This mandates high capital expenditure for specialized GPU hardware if operating at hundreds of Gigabits/second network scales.
- **Physical Mitigation Design:** The research deliberately constrained the system to recommend actions (e.g., Recommend Firewall Rules) rather than executing physical interventions on routers to prevent Self-Denial of Service (Self-DoS). However, this restricts true Real-Time Blocking capabilities.

6.4 Future Development Directions

Stemming from these limitations, future expansion trajectories for the system include:

- **Federated Learning:** Expanding SENTINEL into a decentralized architecture. Instead of sharing privacy-violating network logs, SOC endpoints share only learned model parameters regarding novel malware variants.
- **Multi-Agent System (MAS):** Decomposing the monolithic LangGraph Agent into specialized sub-agents: Malware Analyst Agent, Network Analyst Agent, and Threat

Intel Agent. These agents would debate prior to issuing a final verdict, further elevating accuracy.

- **Automated Red Teaming:** Constructing an internal Red Team agent to continuously generate sophisticated adversarial payloads targeting Sentinel, thereby self-evaluating and autonomously upgrading the system's defensive posture.

Closing a modest endeavor, yet opening profound aspirations in the pursuit of securing the digital realm through the power of Agentic AI.

Tài liệu tham khảo

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Dataset for Cyber Security in Ad hoc Networks,” in *Proceedings of the International Conference on Information Systems Security and Privacy (ICISSP)*, 2018.
- [2] A. Alsubaei, A. Abuhussein, and S. Shiva, “Security Information and Event Management (SIEM) Features, Challenges, and Solutions,” *IEEE Access*, vol. 9, pp. 121111–121128, 2021.
- [3] P. M. M. S. Silva *et al.*, “The Big Data Security Challenges in the Era of Cloud Computing,” *Computer Networks*, vol. 156, pp. 102–115, 2019.
- [4] M. Alshamrani *et al.*, “A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges, and Research Opportunities,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1851–1877, 2021.
- [5] S. Hassan, M. A. Saleem, and O. E. Ogu, “Alert Fatigue in Cybersecurity: A Review,” *IEEE Access*, vol. 10, pp. 58632–58645, 2022.
- [6] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [7] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [8] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [9] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [10] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [11] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.